Part C. Incident Response Runbooks

Ironbridge National Bank

Use this document to decide what kind of incident is occurring, when to escalate or close, and what response phase comes next. Exact commands, queries, and host-level procedures are intentionally kept in the companion Runbook.

Playbook 1: PHISHING / BUSINESS EMAIL COMPROMISE

Purpose

Identify and respond to phishing emails, malicious attachments, credential theft, or fraudulent payment requests.

Identification Criteria

Investigate when one or more of the following occur:

- Unexpected or spoofed sender
- Suspicious sender domain
- Suspicious link or attachment
- Urgent request for credentials or payment
- User reports clicking a suspicious link
- User reports entering credentials
- Suspicious authentication occurs after the email was received

Incident Decision Criteria

- False Positive: Email is legitimate and no suspicious authentication or malicious indicators exist.
- Suspicious: Email contains suspicious indicators but compromise has not been confirmed.
- Confirmed Incident: Malicious content, credential theft, unauthorized authentication, or fraudulent activity is confirmed.

Decision Point

Escalate if:

- Malicious link or attachment is confirmed.
- User entered credentials into a suspicious site.
- Unauthorized or abnormal authentication is identified.
- Fraudulent payment or account activity is suspected or confirmed.
- Additional users or systems may be affected.

Close if:

- Sender and message are verified as legitimate.
- Links/attachments contain no malicious indicators.

- No suspicious authentication or account activity is identified.
- No credentials, systems, or transactions were compromised.

Close as false positive/benign only after documenting the investigation and preserving required evidence.

Containment

- Tell the user not to interact further with the email.
- Prevent fraudulent payment processing.
- Restrict/reset compromised accounts as appropriate.
- Block confirmed malicious indicators through approved controls.

Eradication

- Remove malicious messages/files.
- Reset compromised credentials.
- Remove malicious persistence if endpoint compromise occurred.
- Correct the security weakness that enabled compromise.

Recovery

- Restore legitimate account access.
- Monitor the affected account.
- Confirm no unauthorized transaction occurred.
- Verify no additional users were compromised.

Evidence to Preserve

- Original reported email/message and full headers or available metadata
- Sender, recipient, subject, timestamps, URLs, and attachment names/types
- Screenshots or copies of suspicious content
- Authentication logs for the affected user and relevant Splunk results
- Record of whether links were clicked or credentials entered
- Account or transaction evidence if compromise/fraud is suspected
- Analyst notes, timeline, containment actions, and final disposition

Lessons Learned

Document the attack method, indicators, affected users, response timeline, and security controls that should be improved.

PCI DSS: Requirements 8 and 12.

Playbook 2: MALWARE INFECTION

Purpose
Identify and respond to malicious software executing on an Ironbridge system.

Identification Criteria
Investigate when you identify:

- Defender/anti-malware alert
- Unknown process
- Unexpected service
- Unexpected scheduled task
- New persistence mechanism
- Unusual outbound connection
- Significant difference from the A2/A3/A4 baseline

Incident Decision Criteria
- False Positive: Process/service/file is verified as legitimate.
- Suspicious: Unknown process, service, task, or connection requires additional investigation.
- Confirmed Incident: Malicious process/file, Defender detection, persistence mechanism, or correlated malicious activity is confirmed.

Decision Point
Escalate if:

- Defender or another security control confirms malware.
- A malicious or unexplained process/file is identified.
- Persistence is discovered.
- Suspicious outbound connections correlate with the process.
- Multiple systems or accounts may be affected.

Close if:

- The process/service/file is verified as legitimate.
- No malicious persistence or suspicious connections exist.
- Findings match the known-good baseline.
- No additional indicators of compromise are identified.

Close as false positive/benign only after documenting the investigation and preserving required evidence.

Containment
- Isolate the affected system using the approved process.
- Preserve evidence.
- Restrict compromised accounts if applicable.

Eradication
- Stop malicious processes.

- Remove malicious files.
- Remove persistence.
- Correct the original entry point.

Recovery

- Restore the host to a known-good state.
- Compare it against the baseline.
- Verify malicious indicators are gone.
- Restore normal connectivity.

Evidence to Preserve

- Original Defender/anti-malware alert or other detection
- Process, service, scheduled-task, and network-connection evidence
- Relevant suspicious file names/paths and approved file hashes
- Recently modified-file findings and comparison to A2/A3/A4 baseline
- Relevant host and Splunk logs
- Evidence of persistence or affected accounts, if present
- Analyst timeline, containment actions, and final disposition

Lessons Learned

Determine initial access, privileges obtained, persistence used, systems contacted, and why existing controls did or did not detect the activity.

PCI DSS: Requirements 5, 6 and 10.

Playbook 3: RANSOMWARE

Purpose
Detect and respond to ransomware affecting the Ironbridge file server or endpoints.

Identification Criteria
Investigate when you observe:

- Large number of files changing rapidly
- Unexpected file extensions
- Ransom note
- Files becoming inaccessible
- Unusual file-share activity
- One account modifying unusually large numbers of files

Incident Decision Criteria
- Suspicious: Abnormal spike in file changes.
- Confirmed Incident: Rapid file changes combined with unexpected extensions, ransom-note artifacts, or other confirmed ransomware indicators.

Decision Point
Escalate if:

- Rapid or widespread file modification is occurring.
- Unexpected encrypted/file extensions appear.
- A ransom note or other ransomware artifact is discovered.
- A user/system is modifying an abnormal number of files.
- File-share impact is spreading.

Close if:

- File activity is explained by authorized business activity.
- No ransomware artifacts are found.
- Files remain accessible and intact.
- No malicious process or account activity is identified.

Close as false positive/benign only after documenting the investigation and preserving required evidence.

Containment
- Isolate the source host.
- Restrict the responsible account.
- Prevent further access to the file share.
- Preserve evidence.

Eradication
- Identify and remove malicious processes.
- Remove persistence.

- Determine initial entry point.
- Correct the exploited weakness.

Recovery

- Restore affected files from known-good backup/snapshot.
- Verify file integrity.
- Confirm malicious activity has stopped.
- Restore access.

Evidence to Preserve

- File-change timeline and samples of affected filenames/extensions
- Ransom-note artifacts, if present
- File-share activity and account responsible for modifications
- Relevant Windows/Splunk logs showing abnormal file activity
- Known-good backup/snapshot information used for recovery
- Evidence preserved from affected host before remediation
- Recovery validation and final incident timeline

Lessons Learned

Determine initial entry point, affected files/systems, compromised accounts, and whether earlier detection could have reduced impact.

PCI DSS: Requirements 3, 5 and 12.10.

Playbook 4: DISTRIBUTED DENIAL OF SERVICE (DDoS)

Purpose
Identify and respond to traffic intended to overwhelm the Ironbridge web application.

Identification Criteria
Investigate when:

- Web traffic suddenly increases
- Connection counts significantly exceed baseline
- HTTP errors increase
- CPU/memory utilization increases
- Web application becomes unavailable or slow
- Large numbers of requests originate from suspicious sources

Incident Decision Criteria
- Normal: Traffic remains consistent with baseline.
- Suspicious: Significant unexplained increase in traffic.
- Confirmed Incident: Abnormal traffic is correlated with service degradation or availability problems.

Decision Point
Escalate if:

- Traffic or connection counts significantly exceed the established baseline.
- Increased traffic causes service degradation or unavailability.
- HTTP errors rise significantly with the traffic spike.
- Sources or patterns indicate coordinated abusive traffic.

Close if:

- Traffic is consistent with the normal baseline.
- Increased traffic has a legitimate explanation.
- The application remains healthy and available.
- No sustained abnormal traffic is identified.

Close as false positive/benign only after documenting the investigation and preserving required evidence.

Containment
- Identify malicious traffic sources.
- Apply approved blocking/rate-limiting controls.
- Avoid unnecessarily blocking legitimate users.

Recovery
- Verify web application responds normally.
- Confirm legitimate users can connect.

- Continue monitoring traffic.

Evidence to Preserve
- Traffic and connection-count evidence compared with baseline
- Top source IPs and request patterns
- HTTP error-rate evidence
- CPU/memory utilization during the event
- Web-service availability/status evidence
- Relevant Splunk traffic searches and timestamps
- Blocking/rate-limiting actions and post-recovery validation

Lessons Learned
Review baseline thresholds and determine whether rate limits, alerts, or other controls need adjustment.

PCI DSS: Requirements 1, 6 and 10.

Playbook 5: WEB APPLICATION ATTACK / DEFACEMENT

Purpose
Identify unauthorized modification or exploitation of the Ironbridge web application.

Identification Criteria
Investigate:

- Unexpected website content
- Changed web-root files
- Hash differences
- Unexpected file uploads
- Suspicious HTTP requests
- Unexpected web-root writes

Incident Decision Criteria
- Suspicious: Unexpected requests or file changes.
- Confirmed Incident: Unauthorized web-root modification, changed known-good hash, malicious upload, or confirmed exploit.

Decision Point
Escalate if:

- Web-root files were modified without authorization.
- Current file hashes differ unexpectedly from the known-good baseline.
- A malicious or unauthorized upload is discovered.
- Logs show evidence of successful exploitation.
- Web-service compromise or persistence is identified.

Close if:

- File changes are verified as authorized.
- File hashes match the known-good baseline.
- Suspicious requests were unsuccessful and produced no unauthorized changes.
- No persistence, unauthorized uploads, or other compromise indicators are found.

Close as false positive/benign only after documenting the investigation and preserving required evidence.

Containment

- Prevent continued access through the identified attack path.
- Preserve modified files/logs as evidence.
- Take affected content offline if necessary.

Eradication

- Identify the exploited weakness.
- Remove unauthorized files.
- Remove persistence.
- Patch/correct the vulnerability.

Recovery

- Restore known-good web content.
- Verify hashes.
- Test application functionality.
- Return service to operation.

Evidence to Preserve

- Copies or hashes of modified web-root files
- Known-good baseline hashes for comparison
- Apache access and error logs
- Suspicious HTTP requests and source information
- Unexpected upload artifacts, if present
- Web-root ownership/permission evidence
- Restoration/validation results and incident timeline

Lessons Learned

Document the vulnerability, attack requests, affected files, and security controls that should be improved.

PCI DSS: Requirements 6, 10 and 11.

Playbook 6: BRUTE FORCE / CREDENTIAL STUFFING

Purpose
Identify repeated authentication attempts against Windows, SSH, web, or bank accounts.

Identification Criteria
Investigate:

- Repeated failed authentication
- Multiple failures from one source
- Multiple accounts targeted from one source
- Account lockouts
- Successful login following numerous failures

Incident Decision Criteria
- Normal: Occasional isolated authentication failure.
- Suspicious: Repeated failures exceed your established normal baseline/alert threshold.
- High Priority: Successful login occurs following repeated failures.
- Confirmed Incident: Unauthorized authentication is verified.

Decision Point
Escalate if:

- Failed authentication significantly exceeds the normal threshold.
- One source repeatedly targets one or multiple accounts.
- Account lockouts occur because of suspicious authentication.
- A successful login occurs after repeated failures.
- Unauthorized authentication is confirmed.

Close if:

- Failures are isolated and consistent with normal user mistakes.
- The source/user activity is verified as legitimate.
- No suspicious successful authentication occurred.
- No account compromise indicators are identified.

Close as false positive/benign only after documenting the investigation and preserving required evidence.

Containment
- Restrict/reset affected accounts where compromise is suspected.
- Block confirmed malicious sources through the approved process.
- Preserve authentication logs.

Eradication
- If authentication succeeded:
- Investigate the affected host.
- Look for persistence.

- Look for privilege escalation.
- Rotate compromised credentials.

Recovery
- Restore legitimate account access.
- Monitor authentication.
- Confirm no additional unauthorized logins.

Evidence to Preserve
- Failed-authentication events with timestamps, accounts, and source IPs
- Account lockout events
- Successful logins occurring after repeated failures
- Linux SSH authentication logs, when applicable
- Splunk search results showing failure counts/patterns
- Account reset/restriction or approved blocking actions
- Final determination and monitoring results

Lessons Learned
Review authentication controls, MFA, SSH keys, lockout thresholds, and detection thresholds.

PCI DSS: Requirements 8 and 10.

Playbook 7: AI DEEPFAKE-ENABLED FRAUDULENT TRANSACTION

Purpose
Identify AI-generated impersonation intended to convince employees to approve fraudulent transactions.

Identification Criteria
Check:

- Unexpected payment request
- High urgency
- Unusual communication channel
- Request bypasses normal approval process
- Executive/manager impersonation
- Employee pressured not to verify
- Suspicious authentication associated with request

Incident Decision Criteria
- Suspicious: Unexpected/urgent transaction cannot be independently verified.
- Confirmed Fraud Attempt: Supposed requester independently confirms they did not make the request.

Decision Point
Escalate if:

- The supposed requester independently denies making the request.
- The transaction bypasses normal authorization procedures.
- Associated authentication/account activity is suspicious.
- Money was already transferred or financial loss may have occurred.
- Additional accounts or employees were targeted.

Close if:

- The requester independently verifies the request through an established trusted channel.
- Normal transaction approval procedures were followed.
- Authentication activity is legitimate.
- No fraudulent transaction or account compromise occurred.

Close as false positive/benign only after documenting the investigation and preserving required evidence.

Immediate Containment

- DO NOT APPROVE THE TRANSACTION.
- Verify the requester using a separate, previously established communication channel.
- Do not rely on contact information provided in the suspicious request.

Eradication

- If an associated account was compromised:
- Secure the account.
- Reset credentials.
- Remove unauthorized access.
- Investigate associated systems.

Recovery

- Confirm whether a transaction occurred.
- Follow established transaction/fraud-response procedures.
- Monitor affected accounts.

Evidence to Preserve

- Original suspicious communication or transaction request
- Requester identity claimed, channel, timestamp, amount, and recipient
- Record of independent verification attempt and result
- Associated account-authentication/Splunk evidence
- Transaction status showing whether funds were approved/transferred
- Fraud-response actions and affected-account evidence
- Analyst timeline and final disposition

Lessons Learned

Document how the impersonation was performed and whether verification/dual-approval procedures should be improved.

PCI DSS: Requirements 8 and 12.

Playbook 8: INSIDER THREAT

Purpose
Identify misuse of legitimate Ironbridge access by an authorized user.

Identification Criteria
Investigate:

- Access outside normal responsibilities
- Unexpected administrator/sudo access
- Unauthorized account creation
- Privileged group changes
- Large file access/copy activity
- Access occurring at unusual times

Incident Decision Criteria
- Suspicious: Activity is inconsistent with the user's expected role.
- Confirmed Incident: Unauthorized access, privilege modification, or data access is verified.

Decision Point
Escalate if:

- Unauthorized privileged access is verified.
- An unauthorized account or group-membership change occurred.
- Sensitive information was accessed outside the user's responsibilities.
- Evidence suggests deliberate misuse of legitimate access.
- Additional systems/data may be affected.

Close if:

- Activity is authorized and consistent with the user's assigned responsibilities.
- Privilege/account changes have a verified administrative justification.
- File access is legitimate.
- No unauthorized access or misuse is identified.

Close as false positive/benign only after documenting the investigation and preserving required evidence.

Containment
- Preserve evidence before changing the account.
- Then follow the incident procedure for restricting unauthorized access.

Eradication
- Remove unauthorized privileges.
- Remove unauthorized accounts/access.
- Correct excessive permissions.

Recovery
- Restore correct access.
- Verify affected files/data.
- Continue monitoring.

Evidence to Preserve
- User/account involved and expected job role/access level
- Sudo/admin activity and privileged-group membership evidence
- Account-creation or group-change events
- Login history and relevant timestamps
- File/data access evidence relevant to the investigation
- Authorization or business justification, when activity is legitimate
- Preserved logs, timeline, actions taken, and final disposition

Lessons Learned
Determine whether least privilege, separation of duties, monitoring, or account-management procedures should change.

PCI DSS: Requirements 7, 8 and 10.

Playbook 9: DATA EXFILTRATION

Purpose
Identify unauthorized transfer of sensitive Ironbridge information outside the environment.

Identification Criteria
Investigate:

- Unusual outbound traffic
- Previously unseen destinations
- Large outbound transfers
- Large reads from the file share
- Unexpected egress from a host
- Suspicious process associated with an external connection

Incident Decision Criteria
- Suspicious: Previously unseen/unexpected destination or unusual outbound volume.
- Confirmed Incident: Unauthorized transfer is correlated with sensitive file access or confirmed malicious activity.
- A network connection by itself does not prove data exfiltration.

Decision Point
Escalate if:

- Unauthorized outbound transfer of sensitive data is confirmed.
- Large outbound traffic correlates with sensitive file access.
- A suspicious process is communicating with an unexpected destination.
- Compromised credentials or persistence are associated with the transfer.
- Additional systems/data may be affected.

Close if:

- The destination and transfer are verified as authorized.
- Traffic volume is consistent with normal operations.
- No sensitive information was accessed or transferred without authorization.
- No other compromise indicators are identified.

Close as false positive/benign only after documenting the investigation and preserving required evidence.

Containment

- Stop confirmed unauthorized egress.
- Isolate affected systems if appropriate.
- Restrict compromised accounts.
- Preserve evidence.

Eradication

- Identify initial access.
- Remove persistence.
- Close unauthorized access path.
- Rotate exposed credentials/secrets.

Recovery

- Return systems to known-good configuration.
- Restore connectivity carefully.
- Verify unauthorized transfer has stopped.

Evidence to Preserve

- Source host/account and destination IP/host information
- Connection/process evidence associated with outbound traffic
- Outbound-volume evidence when byte-count data is available
- Sensitive-file access evidence relevant to the suspected transfer
- Relevant Linux, Windows, and Splunk logs
- Evidence showing whether the destination/transfer was authorized
- Containment, recovery validation, and final incident timeline

Lessons Learned

Determine what information was accessed, by whom, for how long, and what control allowed the activity.

PCI DSS: Requirements 1, 3, 4 and 10.

Playbook 10: PRIVILEGE ESCALATION / LATERAL MOVEMENT

Purpose

Identify an attacker gaining elevated privileges or moving between Ironbridge systems.

Important environment path:

vm-team4-dvwa (10.10.60.197)

↓

vm-team4-dc (10.10.60.196)

Identification Criteria

Investigate:

- New administrator/sudo account
- Unexpected privileged-group membership
- Unexpected service
- Unexpected scheduled task
- Suspicious authentication
- Unexpected host-to-host connection
- Changes not present in A2/A3/A4 baseline

Incident Decision Criteria

- Suspicious: Unexpected account, service, task, privilege, authentication, or host-to-host connection.
- Confirmed Incident: Unauthorized privileged access, persistence, or lateral movement is verified.

Decision Point

Escalate if:

- Unauthorized administrator/sudo access is confirmed.
- Unauthorized accounts or privileged-group changes are found.
- Persistence is identified.
- Suspicious authentication or host-to-host activity indicates lateral movement.
- Unexpected activity from 10.10.60.197 to 10.10.60.196 cannot be explained by legitimate administration.
- Both Linux and Windows systems may be affected.

Close if:

- Accounts, privileges, services, tasks, and connections match the known-good A2/A3/A4 baseline.
- Host-to-host activity is verified as legitimate administration.
- No unauthorized privilege changes or persistence exist.
- Authentication activity is legitimate and no additional indicators of compromise are identified.

Close as false positive/benign only after documenting the investigation and preserving required evidence.

Containment

- Isolate affected host.
- Restrict compromised account.
- Preserve evidence.
- If Linux → DC movement occurred, investigate both systems.

Eradication

- Remove unauthorized privileges.
- Remove persistence.
- Remove unauthorized accounts.
- Correct the weakness that enabled escalation/movement.

Recovery

- Compare both hosts against known-good baselines.
- Verify expected accounts.
- Verify expected services/tasks.
- Verify network connections.
- Restore normal access.

Evidence to Preserve

- Linux and Windows authentication/privilege logs
- Sudo/admin membership before and after comparison
- New-account and privileged-group-change events
- Process, service, scheduled-task, and network-connection evidence
- Evidence of unexpected 10.10.60.197 to 10.10.60.196 activity
- Comparison against A2/A3/A4 known-good baselines
- Persistence artifacts, affected accounts/hosts, timeline, and final disposition

Lessons Learned

Reconstruct:

Initial Access

↓

Initial Host

↓

Privilege Escalation

↓

Lateral Movement

↓

Target System

Determine which segmentation, access-control, hardening, or monitoring control could prevent recurrence.

PCI DSS: Requirements 7, 8 and 10.